

COMP3052.SEC Computer Security

Session 08: Network Security



Acknowledgements

- Some of the materials we use this semester may come directly from previous teachers of this module, and other sources ...
- Thank you to (amongst others):
 - Michel Valstar, Milena Radenkovic, Mike Pound, Dave Towey, ...

This Session

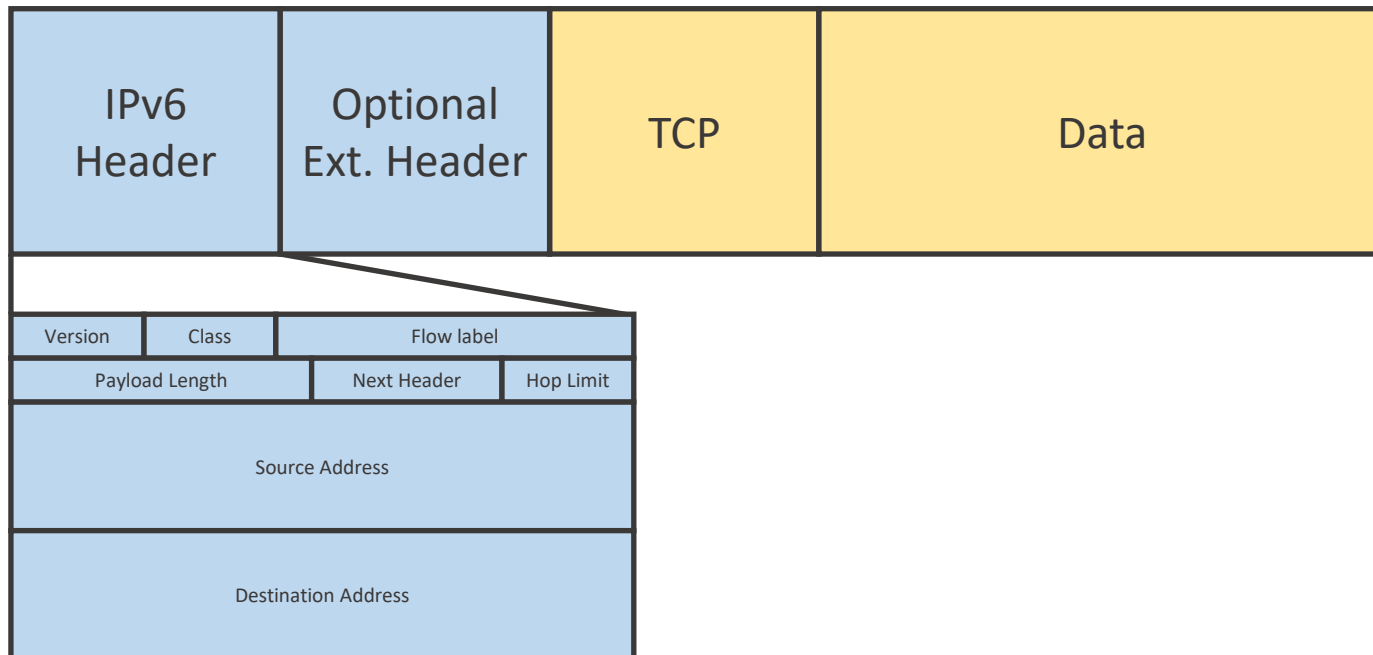
- TCP/IP
- IPSec
- ARP Cache Poisoning
- DNS Spoofing
- Denial of Service Attacks

Two Threat Models

- Passive attackers
 - Eavesdropping / wiretapping / sniffing
 - Traffic analysis
- Active attackers
 - Spoofing attacks (phishing, email)
 - Squatting attacks

TCP/IP - Nesting Headers

- Each protocol carries the protocol in the layer above by appending headers to it



IP Security

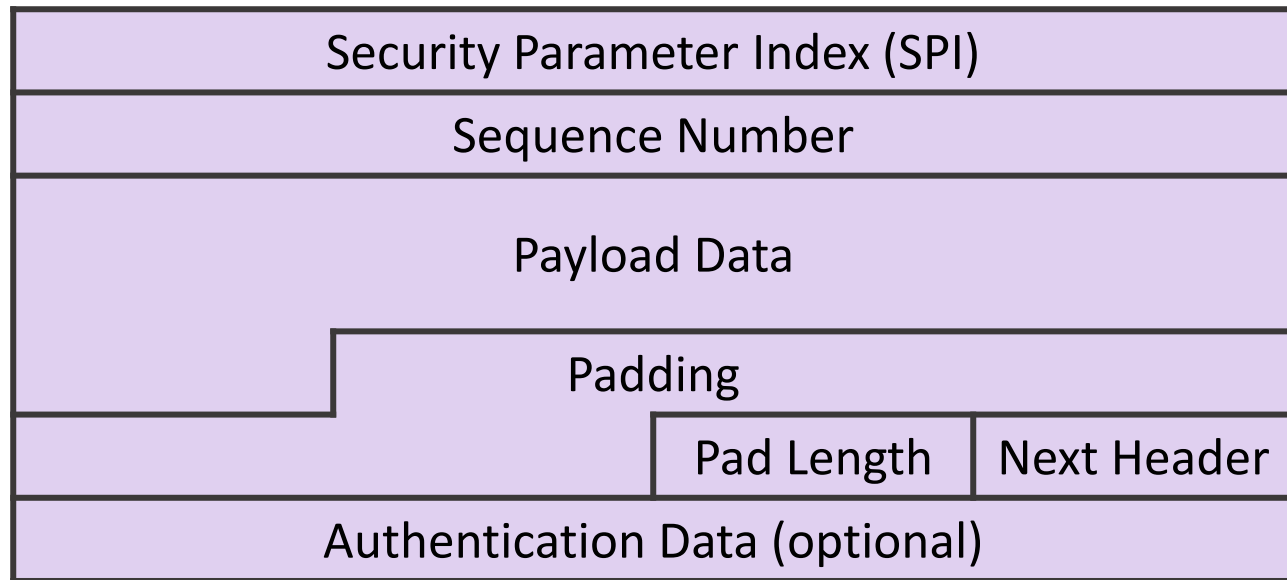
- IP is connectionless and stateless
 - Best effort service
 - No delivery guarantee
 - No order guarantee
- } Provided by TCP
- IPv4 No guaranteed security support
 - IPv6 security support is guaranteed - IPSec

IPSec

- Optional in IPv4, mandatory support in IPv6
- Two major security mechanisms
 - IP Authentication Header (AH)
 - IP Encapsulating Security Payload (ESP)
- Does not contain any mechanisms to prevent traffic analysis

Encapsulating Security Payload (ESP)

- Includes an additional header within the IP packet that describes what encryption and authentication is in use



Transport vs Tunnel Modes

- Transport mode simply encrypts packets, providing host-to-host encryption but using the original header
- Prevents contents being read, but doesn't stop traffic analysis or manipulation of the header



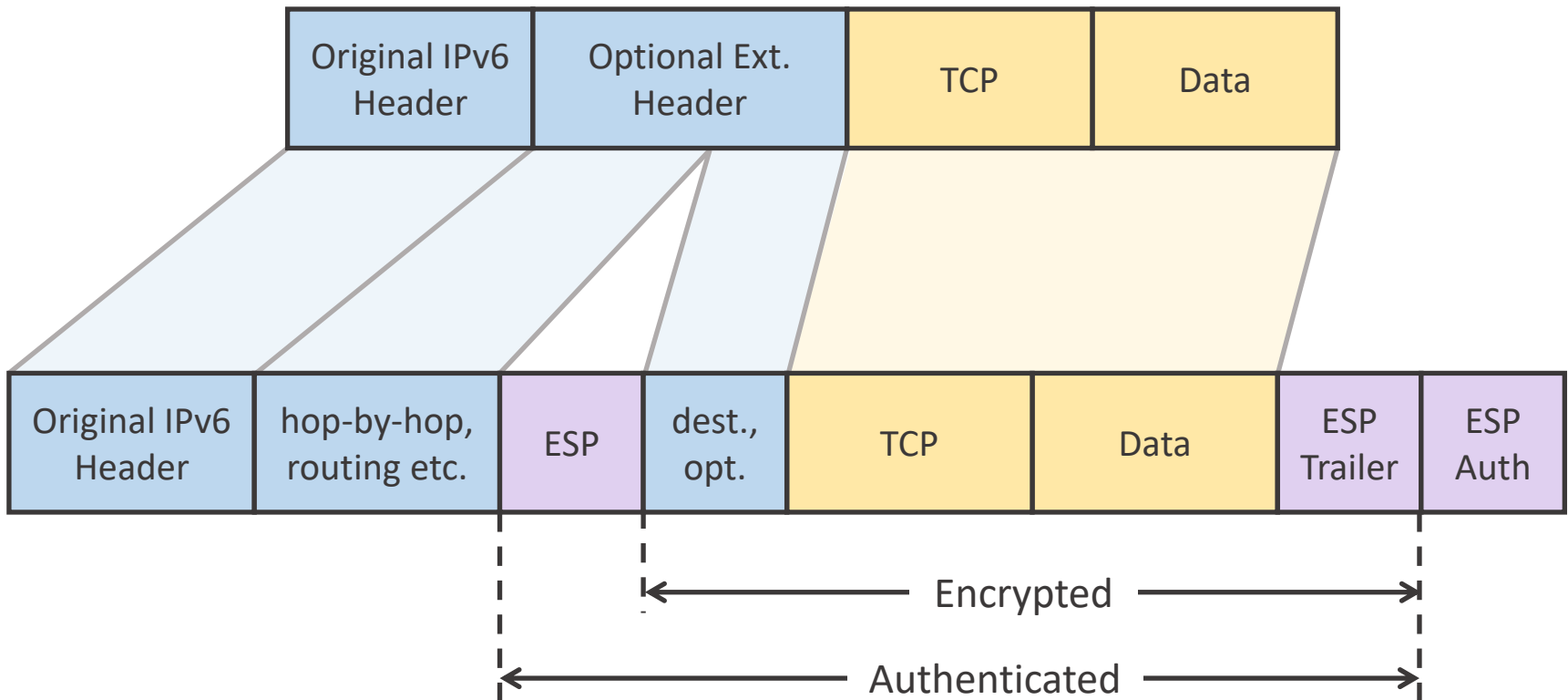
Transport vs Tunnel Modes

- Tunnel mode (usually gateway-to-gateway) protects some segment of a channel with encryption
- Provides some resistance to traffic analysis, and completely protects manipulation of the payload
- VPNs (Virtual Private Networks) are commonly implemented this way

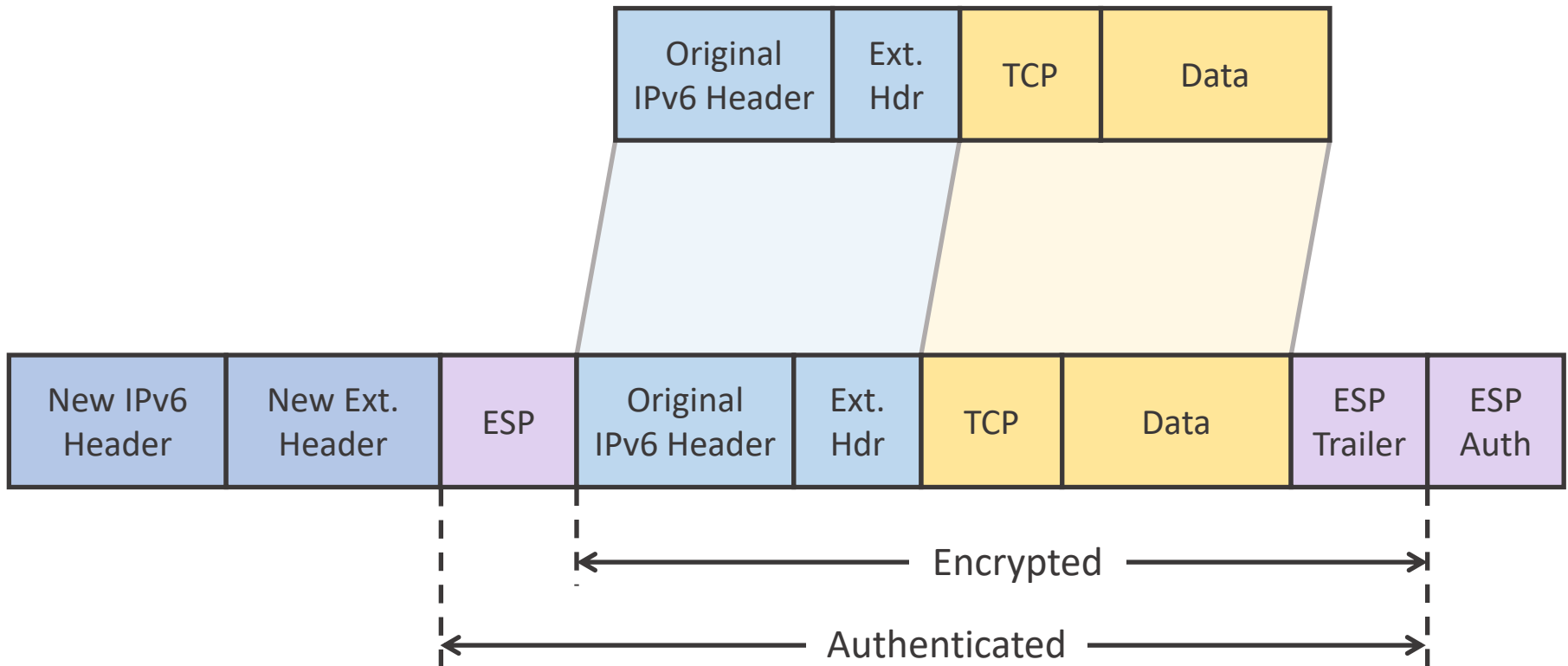


ESP in Transport Mode

- ESP uses either Transport or Tunnel modes

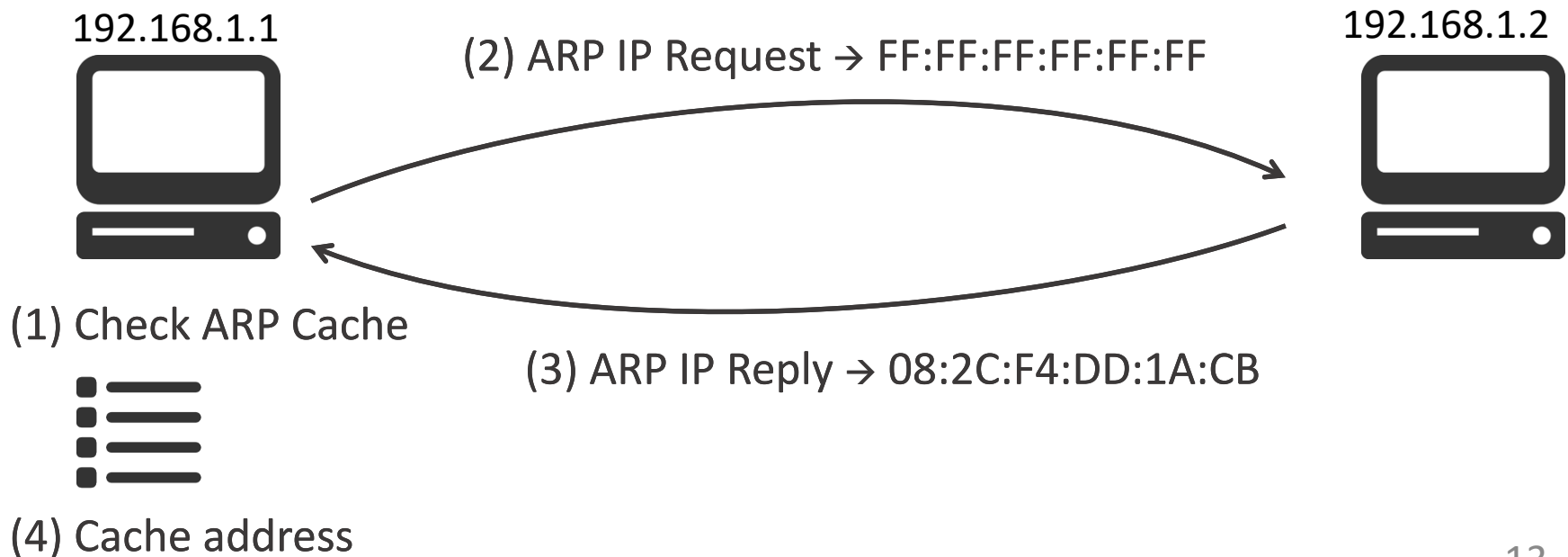


ESP in Tunnel Mode



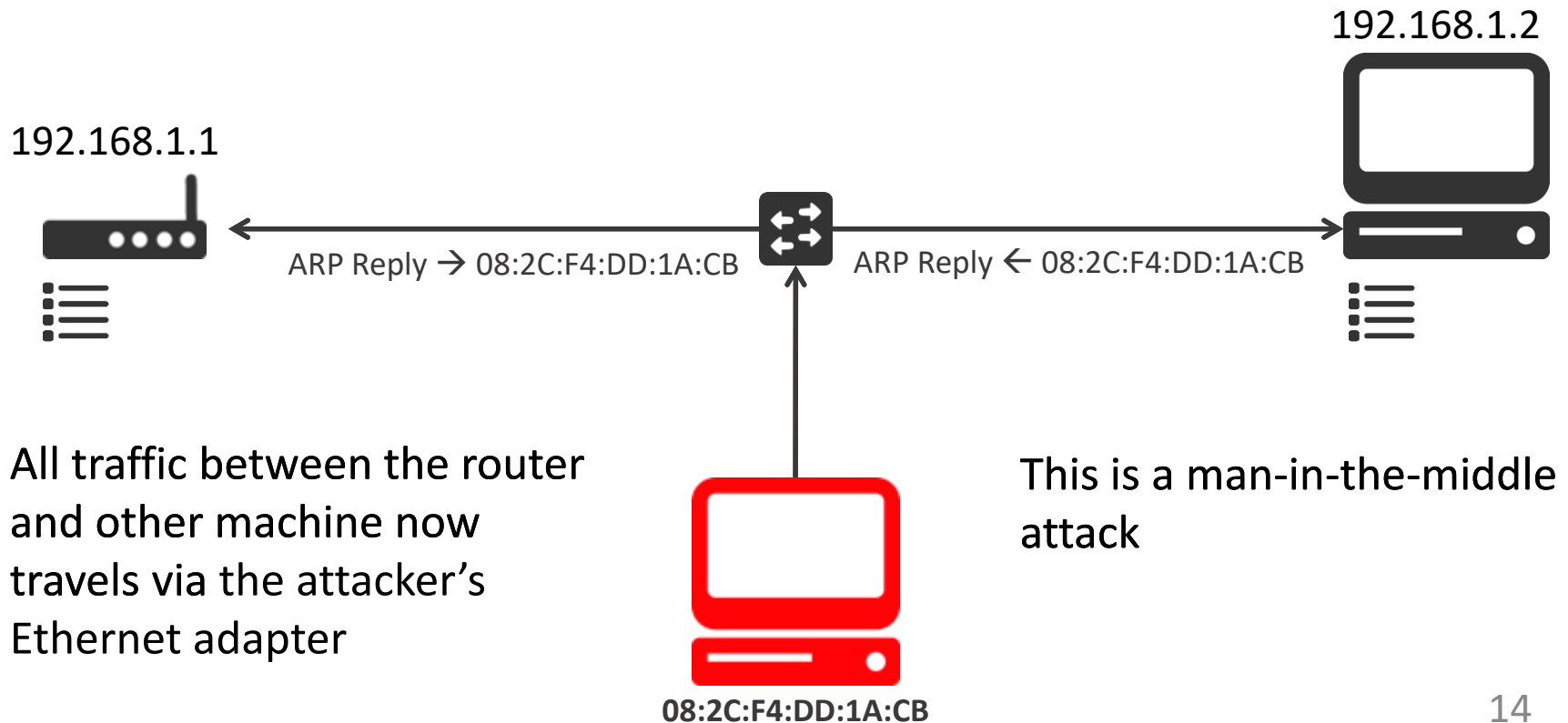
Address Resolution Protocol (ARP)

- ARP is a protocol used (in IPv4) to obtain physical MAC (Media Access Control) addresses for given IPs.
- A MAC address is a hardware identifier embedded in a network interface card (NIC) by the manufacturer, often referred to as a physical or hardware address.
- MAC is used at the data link layer (Layer 2) of the OSI model, unlike IP addresses which operate at the network layer.

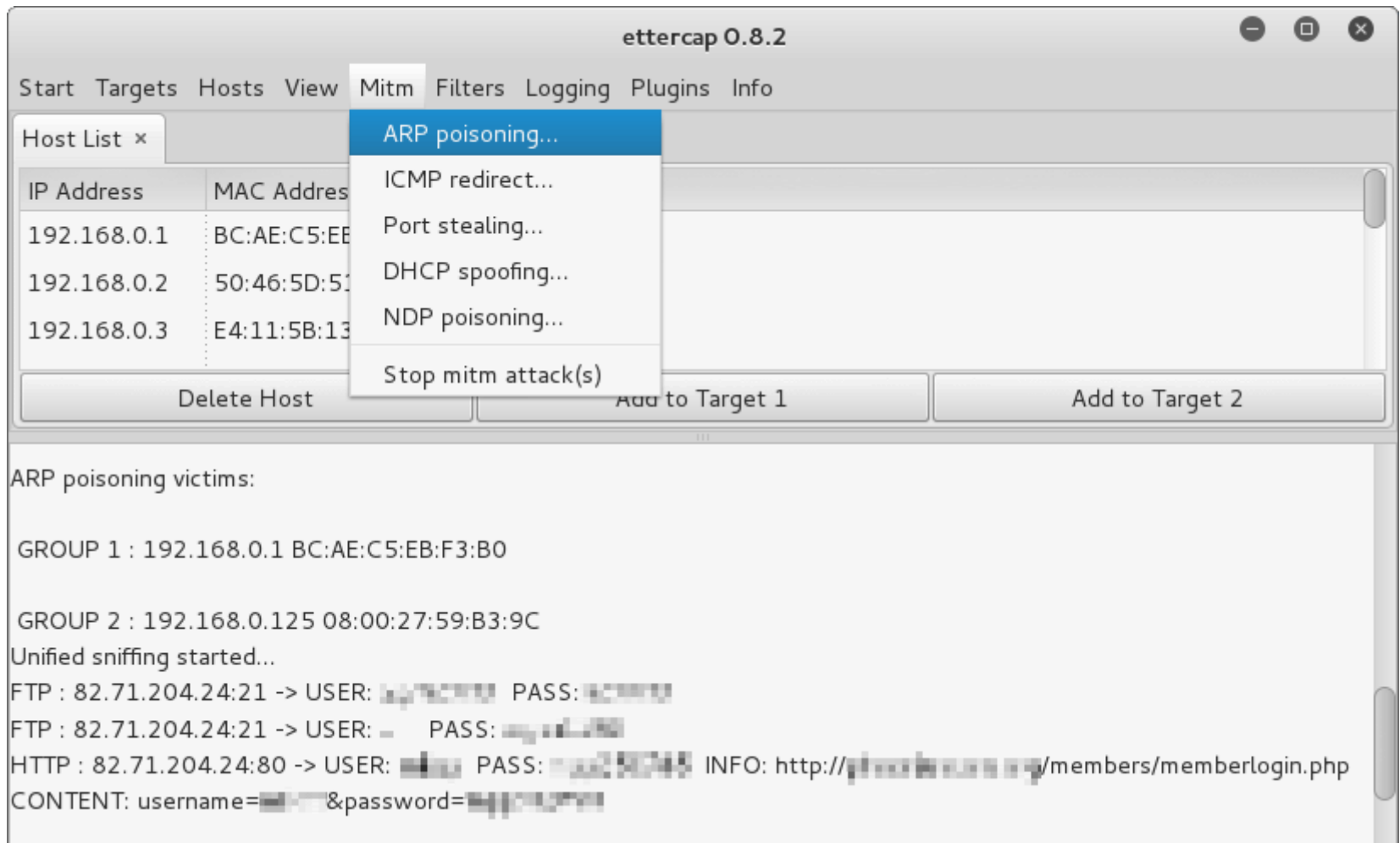


ARP Cache Poisoning

- The attacker can simply send an unrequested ARP reply, and overwrite the MAC address in a host's ARP cache with their own



ARP Cache Poisoning

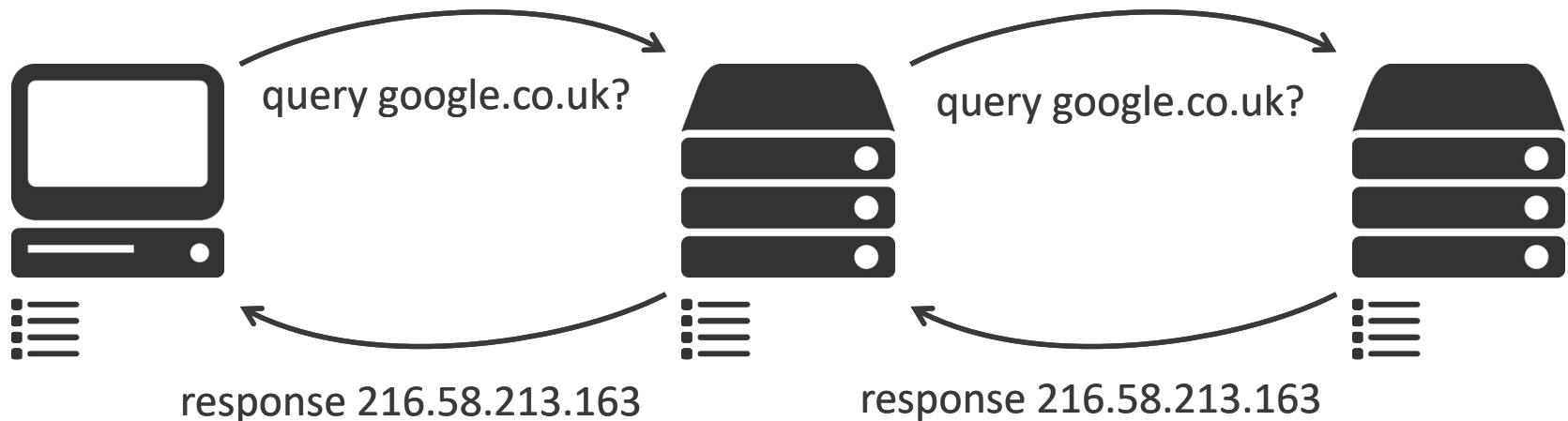


ARP Protection

- Some OSs ignore unsolicited ARP reply, or can be configured to use ARP differently
- Some software, such as intrusion detection packages, will include ARP spoofing detection
 - Maintain a log of current MAC:IP assignments and ARP requests / replies
 - Allows us to spot suspicious messages such as unsolicited ARP replies

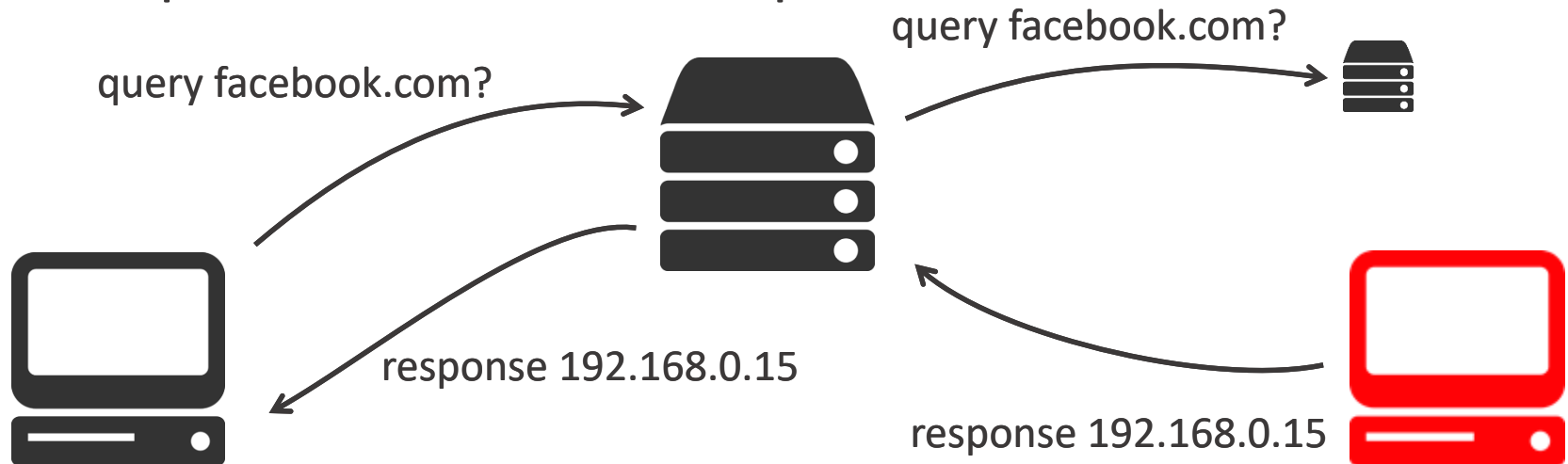
Domain Name System (DNS)

- DNS translates domain names into IP addresses
 - E.g. nottingham.ac.uk → 128.243.80.167
- DNS packets are UDP
 - Stateless, on the transport layer
- DNS resolvers will cache the IPs for a while



DNS Spoofing

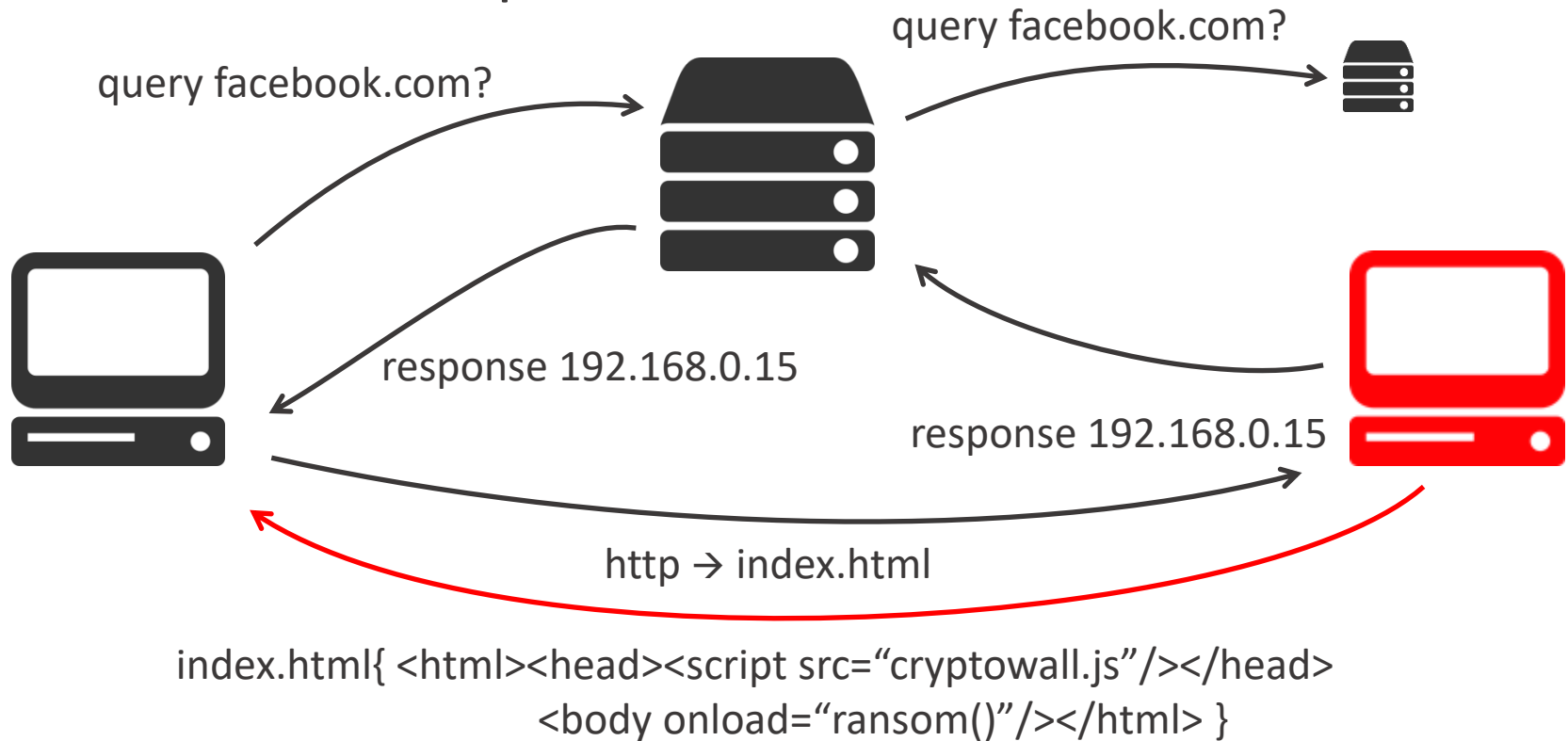
- If the attacker can poison the cache of a nameserver people are using, the attacker can replace a website lookup with their IP



- Kaminsky attack

DNS Spoofing

- If the attacker can poison the cache of a nameserver people are using, they can replace a website lookup with their IP



DNS Protection

- Random query numbers help protect against spoof replies
- Since the Kaminsky attack, most resolvers now randomise the source port too
- DNSSEC aims to tackle DNS exploits by authenticating the name server and providing integrity for the messages



The connection has timed out

The server at is taking too long to respond.

- The site could be temporarily unavailable or too busy. Try again in a few moments.
- If you are unable to load any pages, check your computer's network connection.
- If your computer or network is protected by a firewall or proxy, make sure that Firefox is permitted to access the Web.

Try Again

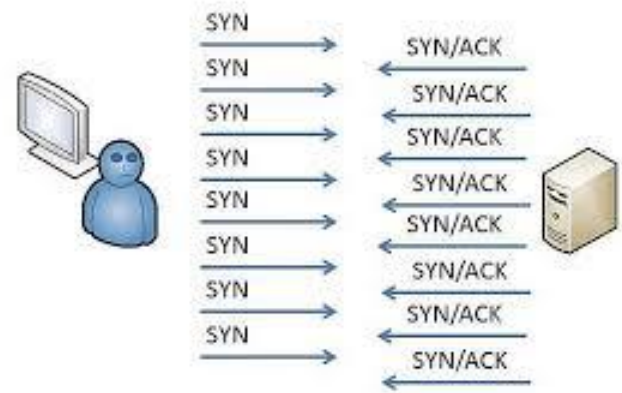
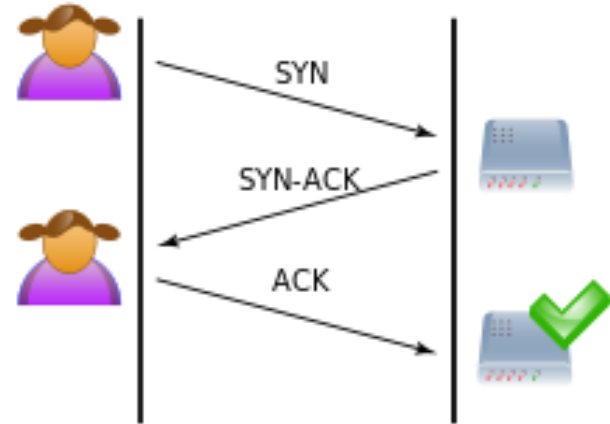
Denial of Service

Denial of Service Attacks

- A denial of service attack is an attempt to make a machine or network resource unavailable to its authorised / intended users
- This will usually involve flooding a machine with enough requests that it can't serve its legitimate purpose
 - E.g. Ping flood
- A distributed denial of service occurs where there is more than one attacking machine

Simple Attack Example

- TCP Syn Flooding
 - Attacker initiates a genuine connection but then immediately breaks it
 - Attacker never finishes 3-way handshake
 - Victim is busy with the timeout
 - Attacker initiates large number of syn requests
 - Victim reaches its half-open connection limit
 - Denial of service

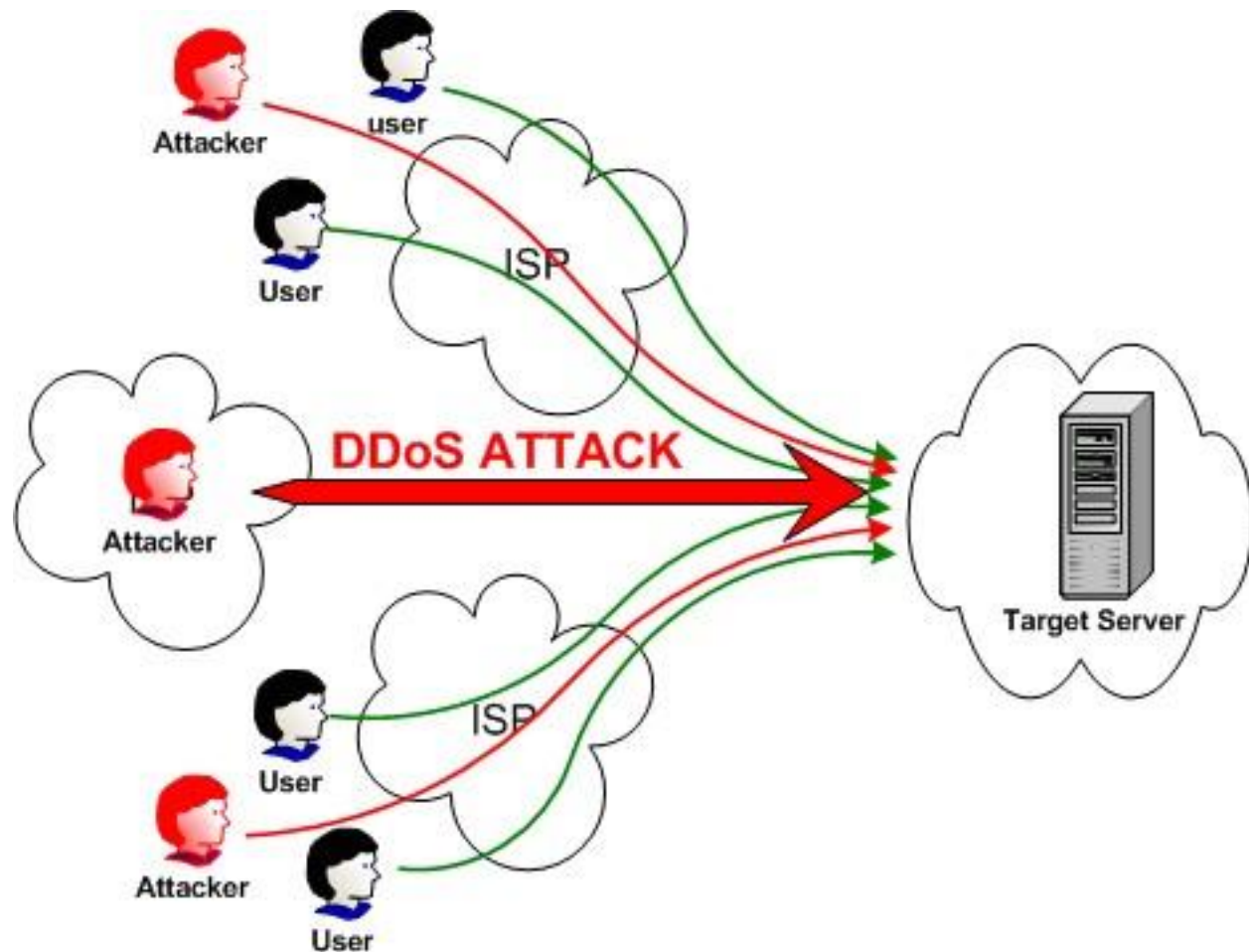


Low and Slow

- Slowloris
 - Open numerous connections to a server
 - Begin an HTTP request, but never actually finish it
- R-U-Dead-Yet?
 - Similar to slowloris
 - Begin an extremely long HTTP POST, send tiny amounts at a time

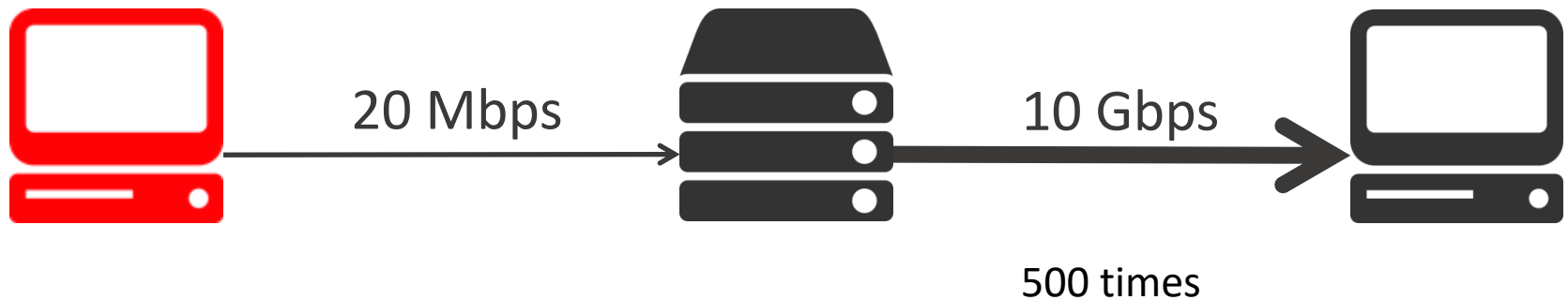


Distributed Denial of Service (DDoS) Attack Example



Amplification Attacks

- Regular attacks are attacker's bandwidth vs attacker's target's
- Amplification attacks utilise some aspect of a network protocol to increase the bandwidth of an attack



DNS Amplification

- Recursive resolvers respond to DNS queries then return a response
- This response can be many times larger than the query

dig +bufsize=4096 +dnssec ANY gov.uk

64 bytes

15 times

998 bytes

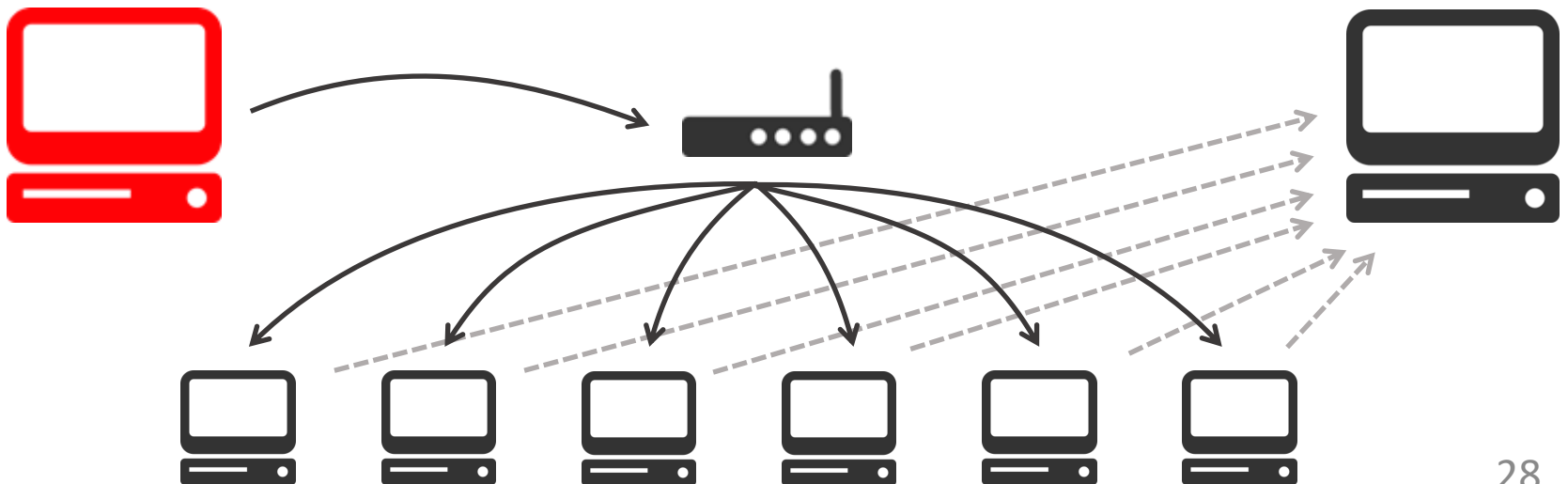
```
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 58774
;; flags: qr rd ra; QUERY: 1, ANSWER: 10, AUTHORITY: 0, ADDITIONAL: 16

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: do; udp: 4000
;; QUESTION SECTION:
;gov.uk.                IN ANY

;; ANSWER SECTION:
gov.uk. 42518 IN A 23.235.37.144
gov.uk. 42518 IN A 23.235.33.144
gov.uk. 42518 IN NS ns2.ja.net.
gov.uk. 42518 IN NS ns0.ja.net.
gov.uk. 42518 IN NS ns4.ja.net.
gov.uk. 42518 IN NS auth50.ns.de.uu.net.
gov.uk. 42518 IN NS auth00.ns.de.uu.net.
gov.uk. 42518 IN NS ns1.surfnet.nl.
gov.uk. 42518 IN NS ns3.ja.net.
gov.uk. 42518 IN RRSIG A 8 2 86400 (
20160306140746 20160205140746 64425 gov.uk.
lhXkrom/IFKOnSJnHGnv/me9/CVITP3eZS5102Dyjq/C
4J1YoSg3JPDvLgz8Ucs0q02y+ohcmDCvyQB7SX72L31V
fZBbRwQAykwNJ5/LrGI3oLqwwwQaBVbCWuLq8eE8h45BS
KEdznQh9X7VWj9T++uily8n7oY+i7s2YkI 87Nd7k=)
```

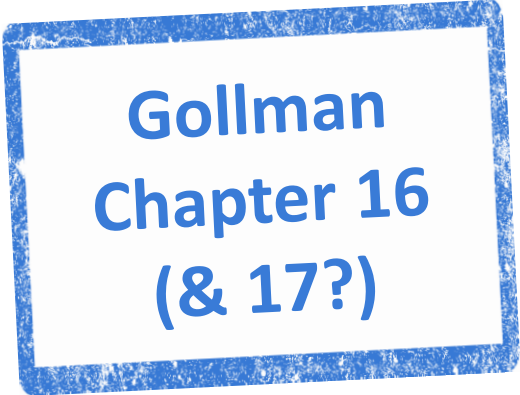
Smurf and Fraggle Attacks

- Smurf attacks broadcast an ICMP Ping request to a router, but with a spoofed IP belonging to the victim
- A Fraggle attack is identical in principle, using UDP echo packets



Summary

- TCP/IP
- IPSec
- ARP Cache Poisoning
- DNS Spoofing
- Denial of Service Attacks



**Gollman
Chapter 16
(& 17?)**